Ejercicios de Entrenamiento 4. Soluciones

Criterios de evaluación:

- RA1.i: Se ha identificado la legislación vigente sobre protección de datos

Ejercicio 1. Identificación de datos personales

Un **dato personal** es cualquier información relacionada con una persona física identificada o identificable.

Campo	¿Es dato personal?	Justificación
Nombre	Sí	Permite identificar directamente a una persona, especialmente combinado con otros datos.
DNI	Sí	Es un identificador que permite identificar de forma inequívoca a una persona.
Fecha de nacimiento	Sí	Es información relacionada con una persona y puede contribuir a identificarla.
Dirección	Sí	Permite localizar o identificar a una persona.
Teléfono	Sí	Permite contactar o identificar a una persona.
Email	Sí	Cuando está asociado a una persona, permite identificarla o contactar con ella.
IP_ultimo_acceso	Sí, en determinados contextos	Una dirección IP puede constituir un dato personal cuando puede vincularse con una persona identificable.
Curso actual	Sí	Asociado a un alumno, proporciona información sobre esa persona.
Nota media	Sí	Es información académica asociada a una persona identificable.
Color favorito	Puede serlo	Aislado puede no identificar a nadie, pero si está asociado a un alumno identificable pasa a ser información personal.

Respuesta clave

Un dato no tiene que ser un nombre o un DNI para ser dato personal. La combinación de diferentes datos también puede permitir identificar a una persona.

Ejercicio 2. Principios de protección de datos

1. Licitud, lealtad y transparencia

El tratamiento de datos debe realizarse de forma lícita, leal y transparente para la persona afectada.

Aplicación al caso

La academia debe informar al alumnado de:

- qué datos recoge
- para qué los utiliza

- cuál es la base jurídica del tratamiento
- durante cuánto tiempo los conserva
- quién puede acceder a ellos
- cuáles son los derechos de las personas

Qué debería hacer el equipo de desarrollo

La aplicación debería incorporar los mecanismos necesarios para que la información sobre el tratamiento sea accesible y comprensible.

2. Limitación de la finalidad

Los datos deben recogerse para **finalidades determinadas, explícitas y legítimas** y no utilizarse posteriormente de forma incompatible con esas finalidades.

Aplicación

Si el email se recoge para gestionar la matrícula y las comunicaciones relacionadas con el curso, no debería utilizarse automáticamente para cualquier finalidad comercial.

Qué debería hacer el equipo

Definir claramente las finalidades para las que se recoge cada información y evitar reutilizarla para objetivos diferentes sin una base jurídica adecuada.

3. Minimización de datos

Solo deben recogerse los datos **adecuados, pertinentes y limitados a lo necesario** para las finalidades del tratamiento.

Aplicación

Si la academia necesita nombre, email y datos académicos para gestionar un curso, probablemente no necesita almacenar:

- aficiones
- color favorito
- otros datos personales que no sean necesarios

Qué debería hacer el equipo

Eliminar del modelo de datos los atributos que no sean necesarios para las funcionalidades previstas.

4. Exactitud

Los datos deben ser correctos y, cuando sea necesario, mantenerse actualizados.

Aplicación

Si un alumno cambia de teléfono, la aplicación debe permitir actualizarlo.

Qué debería hacer el equipo

Proporcionar mecanismos para modificar los datos y evitar que información incorrecta permanezca almacenada indefinidamente.

5. Limitación del plazo de conservación

Los datos no deben conservarse durante más tiempo del necesario para las finalidades para las que fueron recogidos, salvo que exista una razón legal para conservarlos.

Aplicación

La academia no debería conservar indefinidamente todos los datos de antiguos alumnos simplemente porque "podrían ser útiles".

Qué debería hacer el equipo

Establecer políticas de conservación y eliminación o anonimización cuando corresponda.

6. Integridad y confidencialidad

Los datos deben tratarse de manera que se garantice una seguridad adecuada, incluida la protección frente al acceso no autorizado, pérdida, destrucción o daño accidental.

Aplicación

No todos los empleados deberían poder consultar las notas, datos identificativos o cualquier otra información personal.

Qué debería hacer el equipo

Aplicar medidas como:

- control de acceso
- usuarios y roles
- contraseñas seguras
- cifrado cuando corresponda
- copias de seguridad
- registros de actividad
- protección de las comunicaciones

Ejercicio 3. Diseñando una base de datos más respetuosa

3.1.

Una posible solución sería:

```
ALUMNOS
-----------------------------------------------
id
nombre
apellidos
DNI
fecha_nacimiento
direccion
telefono
email
password_hash
curso_actual
nota_media
```

No obstante, la decisión final sobre cada campo debe depender de las necesidades reales de la aplicación.

Análisis de los campos

Campo	¿Se conserva?	Motivo
nombre	Sí	Necesario para identificar al alumno.
apellidos	Sí	Necesarios para identificarlo correctamente.
DNI	Depende	Puede ser necesario para determinadas gestiones, pero no debe recopilarse simplemente "por si acaso".
fecha_nacimiento	Depende	Solo debe almacenarse si existe una finalidad legítima y necesaria.
direccion	Depende	Puede ser necesaria para determinadas gestiones, pero no para todas las plataformas educativas.
telefono	Depende	Puede ser necesario para contacto, pero debe justificarse.
email	Sí	Necesario para acceder o comunicarse con el alumno.
contraseña	Sí, pero nunca en texto plano	Debe almacenarse mediante un mecanismo seguro de hashing adecuado para contraseñas.
IP_ultimo_acceso	Depende	Puede ser necesaria para seguridad, auditoría o funcionamiento, pero debe existir una finalidad y un plazo de conservación adecuado.
curso_actual	Sí	Necesario para gestionar la matrícula.
nota_media	Sí	Necesario si la aplicación gestiona calificaciones.
numero_tarjeta	No, salvo necesidad específica y con garantías	Lo habitual es delegar el pago en un proveedor especializado y evitar almacenar datos de tarjeta innecesariamente.
aficiones	No	No son necesarias para gestionar la matrícula ni el curso.
color_favorito	No	No existe una necesidad para la finalidad planteada.

Información adicional necesaria

Además del modelo de datos, la aplicación debería contemplar información y mecanismos relacionados con:

- finalidad del tratamiento
- base jurídica
- información al usuario
- gestión de derechos
- plazos de conservación
- control de accesos
- medidas de seguridad

3.2. ¿Por qué no debemos guardar todos los datos?

Porque el principio de **minimización de datos** establece que solo deben tratarse los datos adecuados, pertinentes y necesarios para las finalidades previstas.

Además, almacenar datos innecesarios:

- aumenta el riesgo en caso de una brecha de seguridad
- aumenta las obligaciones de protección
- dificulta la gestión de los derechos de las personas
- incrementa la cantidad de información que debe proteger la empresa

Conclusión: una base de datos no debe diseñarse pensando "¿qué datos podemos guardar?", sino "**¿qué datos necesitamos realmente para que la aplicación funcione?**".

Ejercicio 4. Derechos ARSULIPO

Caso	Derecho	Explicación
A	Acceso	Laura quiere conocer qué datos personales tiene la academia sobre ella.
B	Rectificación	Quiere corregir un dato incorrecto.
C	Supresión	Solicita que sus datos sean eliminados cuando proceda.
D	Portabilidad	Solicita recibir sus datos en un formato estructurado y poder trasladarlos a otro responsable cuando se cumplan los requisitos.
E	Oposición	Se opone a determinados tratamientos, por ejemplo, determinados usos comerciales, cuando proceda.
F	Limitación	Solicita que se limite temporalmente el tratamiento en determinadas circunstancias.

ARSULIPO

Recuerda:

A → Acceso
R → Rectificación
S → Supresión
L → Limitación del tratamiento
I → *No corresponde a una inicial independiente del nombre de un derecho; pertenece al derecho anterior de limitación*
P → Portabilidad
O → Oposición

Ejercicio 5. Seguridad de la base de datos

5.1. y 5.2

Problema 1. Todos los empleados utilizan el mismo usuario

Esto impide saber qué persona ha realizado una determinada operación y dificulta aplicar correctamente el principio de control de acceso.

Solución: utilizar cuentas individuales y permisos asociados a roles.

Problema 2. Contraseñas almacenadas directamente

Guardar contraseñas en texto plano supone un grave riesgo de seguridad.

Solución: almacenar únicamente un hash seguro de la contraseña utilizando un algoritmo apropiado para contraseñas y una configuración adecuada.

Problema 3. Cualquier empleado puede consultar todos los datos

Se concede más acceso del necesario.

Solución: aplicar el principio de mínimo privilegio y establecer roles.

Por ejemplo:

```
ADMINISTRADOR
    ↓
Acceso amplio a la gestión

PROFESOR
    ↓
Acceso a los datos académicos necesarios

PERSONAL ADMINISTRATIVO
    ↓
Acceso a los datos necesarios para gestión

ALUMNO
    ↓
Acceso únicamente a sus propios datos
```

Problema 4. No existen copias de seguridad

Una pérdida o corrupción de la base de datos podría provocar una pérdida de información.

Solución: establecer copias de seguridad periódicas y procedimientos de recuperación.

Problema 5. No se registra quién accede a los datos

Dificulta detectar accesos indebidos.

Solución: implementar registros de actividad y mecanismos de auditoría adecuados.

Problema 6. No se han establecido medidas de protección

La empresa debe analizar los riesgos y aplicar medidas técnicas y organizativas adecuadas.

Solución: realizar un análisis de riesgos y establecer medidas de seguridad proporcionales al riesgo.

Ejercicio 6. El responsable del tratamiento

6.1. ¿Quién es el responsable?

El responsable del tratamiento sería:

Academia Web S.L.

La razón es que la empresa decide:

- qué datos se recogen
- con qué finalidad
- cómo se utilizan
- cuánto tiempo se conservan
- quién puede acceder a ellos

6.2. Responsabilidades

Entre sus obligaciones se encuentran, entre otras:

1. Garantizar que el tratamiento tiene una base jurídica adecuada.
2. Informar a las personas sobre el tratamiento de sus datos.
3. Respetar los principios de protección de datos.
4. Facilitar el ejercicio de los derechos.
5. Aplicar medidas técnicas y organizativas adecuadas.
6. Mantener los datos correctos y actualizados cuando corresponda.
7. No conservarlos durante más tiempo del necesario.
8. Gestionar adecuadamente los incidentes de seguridad.

9. Seleccionar y controlar adecuadamente a los encargados del tratamiento cuando intervengan terceros.
10. Poder demostrar el cumplimiento de las obligaciones aplicables.

Ejercicio 7. Caso final

Situación

Cualquier usuario puede modificar:

```
/alumnos/1254
/alumnos/1255
/alumnos/1256
```

y acceder a información de otros alumnos.

a) ¿Qué problema existe?

Existe un **fallo de control de acceso/autorización**.

La aplicación está confiando únicamente en el identificador incluido en la URL y no está comprobando correctamente si el usuario autenticado tiene permiso para consultar ese registro.

Es un ejemplo típico de vulnerabilidad de **acceso no autorizado a objetos**.

b) ¿Qué principios pueden verse afectados?

Principalmente:

- **Integridad y confidencialidad**, porque personas no autorizadas pueden acceder a información personal.
- **Responsabilidad proactiva**, ya que la organización debe adoptar medidas adecuadas para garantizar el cumplimiento.

También puede existir un problema relacionado con la **seguridad del tratamiento**.

c) ¿Qué datos podrían quedar expuestos?

Dependiendo de la aplicación:

- nombre
- apellidos
- DNI
- email
- teléfono
- dirección
- fecha de nacimiento

- curso
- calificaciones
- otros datos personales almacenados

La gravedad dependerá de los datos realmente accesibles

d) ¿Qué medidas técnicas aplicar?

La aplicación debe comprobar **en el servidor** que el usuario tiene autorización para acceder al recurso solicitado.

Por ejemplo, conceptualmente:

```
Usuario solicita:
/alumnos/1255

        ↓

Servidor comprueba:
¿El usuario autenticado puede acceder al alumno 1255?

        ↓
   ┌────────────────┐
   SÍ               NO
   │                │
   ↓                ↓
Mostrar datos    Denegar acceso
```

No es suficiente con ocultar enlaces en la interfaz.

También podrían aplicarse:

- autenticación
- autorización basada en roles/permisos
- principio de mínimo privilegio
- validación en servidor
- registros de acceso
- pruebas de seguridad
- revisión del código
- monitorización

e) ¿Debe comunicarse el incidente?

Sí debe **comunicarse internamente al responsable correspondiente** para que pueda valorar el incidente y activar el procedimiento de gestión de brechas de seguridad.

Además, si realmente se ha producido una violación de seguridad de datos personales, el responsable del tratamiento deberá valorar las obligaciones que correspondan, incluida, cuando proceda, la notificación a la autoridad de control y/o a las personas afectadas.

El desarrollador **no debería decidir por su cuenta que "no pasa nada"**.

f) ¿Por qué comunicarlo aunque la aplicación funcione?

Porque que una aplicación "funcione" desde el punto de vista funcional no significa que sea segura ni que cumpla la normativa.

Un desarrollador debe tener en cuenta:

- seguridad
- privacidad
- control de acceso
- protección de los datos
- minimización
- cumplimiento normativo

Un fallo de autorización puede permitir que cualquier usuario acceda a información que no debería poder consultar.